LABORATUVAR 1 · WSR 500 · Kolileme Makinesi

1

Makine ve Emniyet Tanıma

Çıktı: Hazard–Safety Map

Ad Soyad _____ Grup _____ Tarih _____

Kavram: Emniyet fonksiyonu insanı korur (acil stop, kapı kilidi, ışık perdesi). Siber güvenliğin görevi, bu fonksiyonların çalışmasını bozmaya çalışanları durdurmaktır. Önce makinenin neyi, nasıl koruduğunu bilmeliyiz.

Görev A — tehlike bölgelerini korumayla eşleştirin

Tehlike bölgesi	Olası zarar	Koruma önlemi (siz yazın)	Hangi varlık? (A1 / A2 / mekanik)
Karton katlama ve ürün yerleştirme	Ezilme, sıkışma	Kilitli kapak (interlock), ışık perdesi, acil stop; kapak açılınca servo STO	A2 + mekanik koruyucu
Sıcak tutkal ünitesi	Yanık	Sabit koruyucu/izolasyon, uyarı etiketi, bağımsız aşırı sıcaklık termostatı	Mekanik (A10 termostatı)
Çıkış konveyörü	El sıkışması	Sıkışma noktalarında sabit koruyucu, çekme kablolu acil stop	Mekanik + A2
Format değişikliği (kapaklar açık, ayar yapılıyor)	Beklenmedik hareket	Kapak kilit anahtarı, anahtarlı bakım modu (düşük hız), LOTO	A2 + mekanik (LOTO)

Görev B — iki kısa soru

1. Üretim PLC'si (A1) ile emniyet PLC'sinin (A2) ayrı olması neden önemlidir? Tek bir PLC olsaydı ne değişirdi?

   Emniyet fonksiyonu sade, sertifikalı ve nadiren değişen bir yazılımla çalışmalı; üretim PLC'si ise reçete/hız nedeniyle sık değişir ve ağa bağlıdır. Tek PLC olsaydı üretim kodundaki hata veya ele geçirme emniyeti de etkilerdi, her üretim güncellemesinde emniyet doğrulaması tekrarlanırdı.

2. Format değişikliği sırasında bakım personeli koruma kapaklarını açıyor. Uzak erişim modülü (A5) o sırada açıksa bu an neden özellikle tehlikelidir?

   Bu an maruziyetin en yüksek olduğu andır: kapaklar açık, personel tehlike bölgesinde. A5 açıksa uzaktaki biri fark edilmeden parametre değiştirebilir veya bakım modunu atlatıp çevrimi başlatabilir. Önlem: bakım modunda uzak erişim otomatik kapanmalı, emniyet zinciri (A2) uzak komutlardan bağımsız olmalı.

Bu föyün çıktısı **Hazard–Safety Map** → Evidence Pack **EP 01 Machine Safety Map** başlığına oturur.

2

LABORATUVAR 2 · WSR 500 · Kolileme Makinesi

IEC 62443 Mini Workshop

Çıktı: Zone / Conduit Diagram

Ad Soyad | Grup | Tarih

> **Kavram: Zone** = benzer kritiklikteki cihazları bir bölgeye topla. **Conduit** = bölgeler arası her geçişe kontrollü bir kapı koy. 62443'ün maddelerini ezberlemiyoruz, mantığını uyguluyoruz.

Görev A — varlıkları bölgelere ayırın

Varlık listesi
A1 Üretim PLC'si · A2 **Emniyet PLC'si** · A3 HMI (port 80 web arayüzü) · A4 servo sürücüler · A5 **internete açık uzak erişim modülü** · A6 bulut telemetri · A7 Wi-Fi AP (parola kartonda) · A8 2 kilitsiz USB · A9 "admin/admin" servis hesabı · A10 sıcak tutkal ünitesi

1. Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.

   Z1 Emniyet: A2 (kapı kilidi, ışık perdesi, acil stop). Z2 Kontrol: A1, A3, A4, A10. Z3 Servis/DMZ: A5, A6. Z4 Yerel arayüzler (kısıtlı): A7 Wi-Fi, A8 USB. A9 (admin/admin) bölge değil, kapatılması gereken hesap açığıdır.

2. Uzak erişim modülü (A5) hangi bölgeye düşüyor **ve orada KALABİLİR Mİ?** Neden?

   Z3'e düşer (internete açık, en düşük güvenli bölge). Kontrol bölgesiyle aynı düzlemde KALAMAZ: internetten gelen biri tek adımda A1/A3'e ulaşır. Güvenlik duvarlı DMZ'de durmalı, Z2'ye yalnızca izinli geçitle bağlanmalı.

3. Bölgeler arası geçişler (conduit) nerede? Her geçişte ne kontrol edilecek?

   İnternet–Z3: VPN, MFA, kişisel hesap. Z3–Z2: güvenlik duvarı, gerekli port, salt okunur, oturum kaydı. Z2–Z1: dışarıdan komut yok. Z2'den buluta: yalnızca giden, TLS. Z4–Z2: ayrı Wi-Fi ağı, kilitli USB.

Görev B — uzak erişim kararı (6 satır)

Karar	Seçenekler	Seçiminiz + nedeni
Aracı?	Doğrudan / Jump server	Jump server: tek kontrollü giriş noktası, doğrudan erişim yok
Tünel?	Açık / VPN	VPN: açık port yerine şifreli tünel
Kimlik?	Parola / MFA	MFA: çalınan parola tek başına yetmez
Hesap?	Paylaşılan / Kişisel	Kişisel: kim ne yaptı izlenebilir
Kayıt?	Yok / Tam oturum kaydı	Tam oturum kaydı: olay sonrası kanıt ve denetim
Zamanlama?	Sürekli açık / Varsayılan kapalı	Varsayılan kapalı: talep üzerine süreli açılır

Bu föyün çıktısı **Zone / Conduit Diagram** → Evidence Pack **EP 05 Zone & Conduit** başlığına oturur.

LABORATUVAR 3 · WSR 500 · Kolileme Makinesi

3

Threat & Risk + Risk Matrix

Çıktı: Risk Register

Ad Soyad _____ Grup _____ Tarih _____

Kavram: Senaryo beş parçadır: kim → hangi kapı → ne yapar → zincir → **FİZİKSEL** sonuç. Skor = L × S × E (her biri 1–3). Kural: S=3 ise skor düşük olsa bile senaryo öne alınır, insana zarar görünür kalır.
L = olasılık (1 düşük, 3 yüksek) · **S** = şiddet (1 hafif, 3 ciddi yaralanma) · **E** = maruziyet (1 nadir, 3 sürekli).

WSR 500'ün kapıları (ipucu)
İnternete açık uzak erişim · admin/admin hesabı · port 80 HMI · Wi-Fi (karton parola) · 2 kilitsiz USB · bulut telemetri. *Fiziksel sonuç adayları: katlama/yerleştirme bölgesinde el-parmak ezilmesi, sıcak tutkaldan yanık.*

Görev — üç senaryo kurun ve puanlayın

Senaryo (kim→kapı→zincir→fiziksel sonuç)	L	S	E	Skor	Öncelik
Dış saldırgan → internete açık uzak erişim (A5) + admin/admin → PLC'ye girer, bakım modunu atlatıp çevrimi başlatır → kapaklar açıkken katlama bölgesinde el-parmak ezilmesi	3	3	2	**18**	**Kritik**
Yakındaki kötü niyetli kişi → karton parolalı Wi-Fi (A7) + port 80 HMI (A3) → hız/reçeteyi değiştirir → çıkış konveyöründe beklenmedik hız, el sıkışması	2	2	3	**12**	**Yüksek**
İçeriden/ziyaretçi → kilitsiz USB (A8) → zararlı reçete tutkal sıcaklığını yükseltir → kapatma istasyonunda ciddi yanık	1	3	1	**3**	**Düşük (S=3 bayraklı)**

Kritik 18–27 | **Yüksek 9–17** | **Orta 4–8** | **Düşük 1–3**

1. En yüksek öncelikli senaryonuz hangisi? Bir cümleyle: neden bu?

   Senaryo 1: kapı internete açık ve varsayılan parolalı (özel beceri gerekmiyor), sonucu en ağır olan ezilme; tehlike en çok kapaklar açık format değişikliğinde ortaya çıkıyor.

2. S=3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?

   Evet, Senaryo 3 (skor 3, S=3): risk kaydında 'S=3' bayrağıyla skor sırasının dışında, üstte işaretlenir; tutkal ünitesine bağımsız aşırı sıcaklık termostatı zorunlu tutulur, USB'ler kilitlenir.

Altın kural: Zincir "veri çalındı" ile bitiyorsa emniyet bulgusu değildir. Bir adım daha gidin: bu, hattaki insana ne yapar?

Bu föyün çıktısı **Risk Register** → Evidence Pack **EP 04 Risk Assessment** başlığına oturur.

LABORATUVAR 4 · WSR 500 · Kolileme Makinesi

4

Secure Remote Access

Çıktı: Secure Architecture

Ad Soyad | Grup | Tarih

Kavram: İki katman, ikisi de şart: **erişim güvenliği** (girişi zorlaştır: ara nokta, VPN, MFA, kişisel hesap, kayıt, varsayılan kapalı) + **emniyet bağımsızlığı** (girse bile insan korunur).

Görev A — mevcut → hedef

MEVCUT (çizin / yazın)

İpucu: uzak erişim modülü bugün internete DOĞRUDAN açık; üretici servisi arıza kodlarını bu yoldan alıyor.

İnternet → A5 (doğrudan açık, admin/admin, sürekli açık) → düz ağda A1 / A3 / A4. A2'ye de aynı ağdan erişilebilir.

HEDEF (beş ilkeyle yeniden tasarlayın)

İpucu: ara nokta, tünel, kimlik, hesap, kayıt ve zamanlamayı birlikte düşünün.

Servis → VPN + MFA → Jump server (DMZ, kişisel hesap, oturum kaydı) → güvenlik duvarı (salt okunur) → Z2 Kontrol. A2 (Z1) bağımsız. Erişim varsayılan kapalı.

Görev B — functional safety köprüsü

1. Saldırgan tüm önlemlere rağmen içeri girerse emniyet fonksiyonu etkilenir mi? Neden?

   Hayır. A2 ayrı PLC'de, kendi donanım zincirinde (kapı kilidi, ışık perdesi, acil stop, STO) çalışır ve ağdan komut/parametre kabul etmez; saldırgan üretimi bozsa da kapak açıkken hareketi engelleyen zincir etkilenmez.

2. Kapı kilidi ve ışık perdesi zincirinin uzak erişim yolundan etkilenmemesi için **GEREKSİNİMİ** yazın (çözümü değil).

   Emniyet fonksiyonları uzak erişim dahil hiçbir ağ arayüzünden değiştirilemez, devre dışı bırakılamaz veya atlanamaz; parametreleri yalnızca makine başında fiziksel yetkiyle değişir. Haberleşme kaybında güvenli durum: durdurma.

3. Üretici servisi arıza kodlarını uzaktan okuyor. Servisin yetkisi yalnızca okumayla mı sınırlı olmalı, parametre yazabilmeli mi? Neden?

   Varsayılan salt okunur: arıza kodlarını okumak için yazma yetkisi gerekmez. Yazma yalnızca istisnai, süreli, ayrı onaylı ve kayıtlı olmalı; emniyet parametrelerine uzaktan yazma hiçbir koşulda verilmez.

Tarafsızlık notu: Bu föy çözüm tasarlatmaz, gereksinimi tanımlatır. Tasarım kararı firmanızındır.

Bu föyün çıktısı **Secure Architecture** → Evidence Pack **EP 02 + EP 06** başlığına oturur.

5

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad _____ Grup _____ Tarih _____

Kavram: SBOM = yazılım malzeme listesi · CVE = açığın kayıt no'su · CVSS = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: **bileşen var, sürüm etkileniyor, açık ulaşılabilir.**

Kurgusal SBOM

Bileşen	Kurulu sürüm	Uzak erişim modülünden ulaşılabilir mi?
WSR Component X (üretim PLC'si firmware kütüphanesi)	2.4	Evet
HMI web sunucusu	1.9	Evet
Servo sürücü firmware	3.1	Hayır (yalnızca kontrol ağı)
Wi-Fi erişim noktası firmware	5.2	Evet

Verilen zafiyet kaydı (kurgusal)

Bileşen	WSR Component X (üretim PLC'si firmware kütüphanesi)
Etkilenen sürümler	2.4 ve öncesi
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut (sürüm 2.5)

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı SBOM tablosuyla kontrol edin)

   Evet: bileşen var (WSR Component X), sürüm 2.4 etkilenen aralıkta (2.4 ve öncesi) ve uzak erişimden ulaşılabilir (Evet).

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

   Hayır, hemen durdurmam: önce uzak erişimi kapatıp erişimi keserim, yamayı planlı duruşta uygularım.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

   Önce test: ayrı bir test ortamında/yedek PLC'de denerim, sonra planlı duruşta üretime alırım.

4. Bu yama bir safety validation'ı etkiler mi? Nasıl anlarsınız?

   Etkileyebilir: A1 emniyetten ayrı olsa da değişiklik sonrası emniyet fonksiyonları testle yeniden doğrulanır.

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

   Uzak erişimi varsayılan kapalı yapıp VPN + güvenlik duvarıyla ayrı bölgeye alırım; HMI port 80 ve servis hesabını kısıtlar (admin/admin kapatılır), erişimi izlerim ve yama için planlı duruş beklerim.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.